

Marco Integrativo GQM + PRAGMATIC para FAICP

Framework for AI Cybersecurity Practices — Trazabilidad desde Objetivos Nacionales hasta Datos Técnicos

Versión: 1.0 — Abril 2026

Ámbito: España — Aplicación Territorial por CCAA

Marcos de referencia: NIST IR 8596 · AI RMF 1.0 · EU AI Act 2024/1689 · ENS RD 311/2022 · NIS2 2022/2555 · ISO/IEC 42001:2023 · OWASP LLM Top 10 2025 · MITRE ATLAS v5.5

1. Fundamento Metodológico

1.1. La Metodología GQM (Goal-Question-Metric)

La metodología **GQM**, desarrollada originalmente por Victor Basili en la NASA/SEL (1984) y ampliamente validada en ingeniería del software y gestión de calidad, establece que toda medición significativa debe derivarse de manera top-down desde los **objetivos** de la organización, pasando por **preguntas** que interrogan si esos objetivos se están alcanzando, hasta las **métricas** que responden empíricamente a esas preguntas.

La estructura formal de un objetivo GQM es:

```
Objetivo(  
  ANALIZAR      <objeto de medición>  
  CON EL FIN DE <propósito>  
  RESPECTO A    <foco de calidad>  
  DESDE LA PERSPECTIVA DE <actor>  
  EN EL CONTEXTO DE <entorno>  
)
```

Este marco supera la tentación —común en ciberseguridad— de recoger datos técnicos abundantes sin anclarlos en objetivos organizativos ni verificar su utilidad decisonal. Un indicador sin objetivo es ruido. Una pregunta sin métrica es filosofía. GQM es el puente.

1.2. Los Nueve Criterios PRAGMATIC

El framework **PRAGMATIC** (Hubbard & Seiersen, *How to Measure Anything in Cybersecurity Risk*, 2023; ampliado por ISACA CMMI 2024) evalúa la calidad de una métrica de ciberseguridad en nueve dimensiones:

Criterio	Clave	Pregunta de Evaluación
Predictivo	P	¿Anticipa problemas futuros o sólo registra el pasado?
Relevante	R	¿Es material para los objetivos de negocio y misión?
Accionable	A	¿Genera decisiones o acciones concretas?
Genuino	G	¿Mide lo que dice medir, sin sesgos ni manipulación?
Meaningful (Significativo)	M	¿Es comprensible para la audiencia destinataria?
Accurate (Preciso)	Ac	¿Tiene la resolución necesaria para discriminar estados?
Timely (Oportuno)	T	¿Está disponible cuando se necesita para decidir?
Independent (Independiente)	I	¿Está libre de conflictos de interés en su recogida?
Cost-effective (Rentable)	C	¿El coste de medición es proporcional al valor decisional?

La puntuación PRAGMATIC asigna de 1 a 3 puntos por cada criterio (1 = Deficiente, 2 = Aceptable, 3 = Excelente), generando una puntuación máxima de 27 puntos. Las métricas con puntuación ≥ 21 son **recomendadas**; entre 14-20 son **condicionales** (requieren mejoras); por debajo de 14 son **desestimadas** o profundamente reformuladas.

1.3. Integración GQM + PRAGMATIC en el Ciclo FAICP

La integración se realiza en cuatro capas:

CAPA 1: OBJETIVOS ESTRATÉGICOS NACIONALES
↓ (derivación GQM nivel 1)
CAPA 2: OBJETIVOS ORGANIZATIVOS (por sector/CCAA)
↓ (derivación GQM nivel 2)
CAPA 3: PREGUNTAS DE MEDICIÓN
↓ (operacionalización)
CAPA 4: MÉTRICAS FAICP (evaluadas con PRAGMATIC)
↓ (recolección y análisis)
CAPA 5: DATOS TÉCNICOS (logs, SIEM, CMDB, AI-BOM)

Este diseño garantiza que cada dato técnico recolectado tiene un camino trazable hasta un objetivo nacional, y que cada objetivo nacional tiene al menos una métrica que lo interroga empíricamente.

2. Objetivos GQM Nacionales — Nivel 1

Objetivo Nacional N-01

ANALIZAR los sistemas de IA desplegados en organizaciones españolas (públicas y privadas)
CON EL FIN DE conocer el nivel de ciberseguridad específica para IA
RESPECTO A la conformidad con NIST IR 8596, EU AI Act y NIS2
DESDE LA PERSPECTIVA DE AESIA, CCN-CERT e INCIBE
EN EL CONTEXTO DE la Estrategia Nacional de Ciberseguridad 2025 y el Plan de Ciberseguridad 2025 (1.157M€)

Preguntas derivadas:

- Q1.1: ¿Qué proporción de organizaciones con sistemas de IA dispone de una política formal de ciberseguridad IA?
- Q1.2: ¿Cuál es el nivel medio de madurez IGM-FAICP por sector y por CCAA?
- Q1.3: ¿Cuántas organizaciones han completado el inventario AI-BOM (Tier 1 del IR 8596)?

Objetivo Nacional N-02

ANALIZAR los incidentes de ciberseguridad con componente IA registrados por INCIBE y CCN-CERT
CON EL FIN DE cuantificar el impacto operativo y económico de las amenazas IA
RESPECTO A la velocidad de detección, respuesta y recuperación
DESDE LA PERSPECTIVA DE operadores esenciales e importantes (NIS2)
EN EL CONTEXTO DE los 122.223 incidentes INCIBE 2025 (+26% interanual)

Preguntas derivadas:

- Q2.1: ¿Cuál es el MTTR-AI (tiempo medio de respuesta a incidentes IA) por sector?
- Q2.2: ¿Qué porcentaje de incidentes involucró IA adversarial (phishing LLM, deepfakes, prompt injection)?
- Q2.3: ¿Cuántos playbooks de respuesta específicos para IA existen y están probados?

Objetivo Nacional N-03

ANALIZAR la posición competitiva de España en ciberseguridad IA
CON EL FIN DE identificar brechas respecto a líderes europeos y globales
RESPECTO A los indicadores del Cisco CRI 2025 y WEF GCO 2025
DESDE LA PERSPECTIVA DE decisores de política industrial y de I+D+i
EN EL CONTEXTO DE la comparativa internacional (UE, EE.UU., Singapur)

Preguntas derivadas:

- Q3.1: ¿En qué pilares del Cisco CRI 2025 supera España la media global y en cuáles está por debajo?
- Q3.2: ¿Cómo evoluciona el porcentaje de organizaciones en nivel "Mature" en AI Fortification?
- Q3.3: ¿Cuál es la brecha de talento en ciberseguridad IA por CCAA?

3. Objetivos GQM Organizativos — Nivel 2

Objetivo Organizativo O-01 (Función: GOBERNAR)

ANALIZAR los marcos de gobernanza de IA en la organización
CON EL FIN DE verificar que existe estructura formal para gestionar
riesgos de ciberseguridad IA
RESPECTO A la completitud, formalidad y operatividad de la gobernanza
DESDE LA PERSPECTIVA DE el CISO, el DPO y el Comité de Dirección
EN EL CONTEXTO DE los requisitos NIST IR 8596 GV.* y EU AI Act Arts. 9, 49

Preguntas derivadas:

- Q-GV-01: ¿Existe una política formal de ciberseguridad para IA, aprobada por dirección y revisada en los últimos 12 meses?
- Q-GV-02: ¿Están mapeadas todas las dependencias de infraestructura crítica introducidas por sistemas de IA?
- Q-GV-03: ¿Incluye el programa de formación en ciberseguridad módulos específicos sobre IA adversarial?
- Q-GV-04: ¿Existe un proceso formal y documentado de evaluación de riesgos de proveedores de IA?
- Q-GV-05: ¿Hay una función de gobernanza de IA (rol/comité) con mandato explícito y presupuesto asignado?
- Q-GV-06: ¿Están todos los sistemas de IA clasificados conforme al EU AI Act (Anexo III) y registrados en EUDB?

Objetivo Organizativo O-02 (Función: IDENTIFICAR)

ANALIZAR el conocimiento y visibilidad sobre activos de IA y amenazas
CON EL FIN DE garantizar que la organización sabe qué tiene, qué enfrenta
y qué riesgos introduce cada componente de IA
RESPECTO A la exhaustividad del inventario, la cobertura de amenazas
y la calidad de la inteligencia consumida
DESDE LA PERSPECTIVA DE el arquitecto de seguridad IA y el equipo de riesgos
EN EL CONTEXTO DE NIST IR 8596 ID.*, OWASP LLM Top 10, MITRE ATLAS v5.5

Preguntas derivadas:

- Q-ID-01: ¿Existe un AI-BOM completo (modelos, datos de entrenamiento, APIs, dependencias de cadena de suministro) para todos los sistemas de IA en producción?
- Q-ID-02: ¿Se realizan evaluaciones de vulnerabilidades específicas para IA que cubran las 10 categorías del OWASP LLM Top 10?
- Q-ID-03: ¿Consume la organización inteligencia de amenazas adversariales IA (MITRE ATLAS, feeds CTI IA)?
- Q-ID-04: ¿Incorpora el modelo de gestión de riesgos la velocidad de ataque IA (36.000 escaneos/segundo)?
- Q-ID-05: ¿Existe análisis de riesgos de cadena de suministro IA que cubra modelos de terceros, APIs y datasets?

Objetivo Organizativo O-03 (Función: PROTEGER)

ANALIZAR los controles preventivos aplicados a sistemas de IA
CON EL FIN DE reducir la probabilidad y el impacto de incidentes IA
RESPECTO A la cobertura, profundidad y actualidad de los controles
DESDE LA PERSPECTIVA DE el equipo de operaciones de seguridad y arquitectura
EN EL CONTEXTO DE NIST IR 8596 PR.*, OWASP LLM 01/02/03/06, EU AI Act Art. 4

Preguntas derivadas:

- Q-PR-01: ¿Aplica la organización gestión de identidades y accesos específica para sistemas y agentes de IA (no solo usuarios humanos)?
- Q-PR-02: ¿Se implementa el principio de menor privilegio en agentes IA autónomos con acceso a herramientas externas?
- Q-PR-03: ¿Con qué frecuencia y profundidad temática recibe el personal formación sobre amenazas IA (phishing LLM, deepfakes, ingeniería social potenciada por IA)?
- Q-PR-04: ¿Existen controles de protección de datos de entrenamiento e inferencia contra acceso no autorizado y envenenamiento?
- Q-PR-05: ¿Aplica la organización control de versiones formal y prácticas MLOps seguras para gestionar el ciclo de vida de modelos?
- Q-PR-06: ¿Están acotadas y documentadas las capacidades de acción de todos los agentes IA (prevención de agencia excesiva, LLM06)?

Objetivo Organizativo O-04 (Función: DETECTAR)

ANALIZAR las capacidades de detección de anomalías y ataques IA
CON EL FIN DE minimizar el tiempo de permanencia de amenazas IA no detectadas
RESPECTO A la cobertura, la latencia y la fidelidad de la detección
DESDE LA PERSPECTIVA DE el SOC y el equipo de threat hunting
EN EL CONTEXTO DE NIST IR 8596 DE.*, MITRE ATLAS, OWASP LLM01/LLM10

Preguntas derivadas:

- Q-DE-01: ¿Están monitorizadas las comunicaciones de los sistemas de IA con APIs externas (incluyendo modelos SaaS y servicios GenAI)?
- Q-DE-02: ¿Existe monitorización en tiempo de ejecución de los sistemas de IA en producción (comportamiento, outputs, consumo de recursos)?
- Q-DE-03: ¿Con qué frecuencia se evalúa el model drift y data drift, y mediante qué metodología?
- Q-DE-04: ¿Están los analistas del SOC capacitados para detectar las tácticas y técnicas del MITRE ATLAS (IA adversarial)?
- Q-DE-05: ¿Existen controles técnicos específicos de detección y mitigación de ataques de prompt injection (LLM01)?

Objetivo Organizativo O-05 (Función: RESPONDER)

ANALIZAR la capacidad de respuesta ante incidentes específicos de IA
CON EL FIN DE reducir el impacto y el tiempo de respuesta a incidentes IA
RESPECTO A la exhaustividad de los playbooks, la velocidad de respuesta
y el cumplimiento de los plazos de notificación regulatoria
DESDE LA PERSPECTIVA DE el CISO, el equipo de respuesta y el DPO
EN EL CONTEXTO DE NIST IR 8596 RS.*, EU AI Act Art. 73, NIS2 Art. 23

Preguntas derivadas:

- Q-RS-01: ¿Existen playbooks formales y probados para respuesta a los cinco tipos de incidente IA más probables (phishing LLM, deepfake ejecutivo, prompt injection, model drift silencioso, Shadow AI)?
- Q-RS-02: ¿Dispone la organización de capacidades de análisis forense específico para sistemas de IA (logs de inferencia, trazabilidad de decisiones, análisis de prompts)?
- Q-RS-03: ¿Conoce el equipo con precisión los plazos de notificación a AESIA (15 días hábiles, EU AI Act Art. 73) y a la autoridad NIS2 (24 horas)?
- Q-RS-04: ¿Cuál es el MTTR-AI (tiempo medio de respuesta) para incidentes de ciberseguridad en sistemas de IA?

Objetivo Organizativo O-06 (Función: RECUPERAR)

ANALIZAR los planes y capacidades de recuperación de sistemas de IA
CON EL FIN DE garantizar la continuidad del negocio tras incidentes IA
RESPECTO A la completitud de los planes, el RTO-AI alcanzado
y la capacidad de revisar decisiones del sistema comprometido
DESDE LA PERSPECTIVA DE el CIS0, el responsable de continuidad y el DPO
EN EL CONTEXTO DE NIST IR 8596 RC.*, NIS2 Art. 21.2.c, EU AI Act Art. 72.1

Preguntas derivadas:

- Q-RC-01: ¿Incluyen los planes de recuperación procedimientos específicos de rollback de modelos de IA y restauración de datos de entrenamiento no comprometidos?
- Q-RC-02: ¿Cuál es el RTO-AI (Tiempo Objetivo de Recuperación) para los sistemas de IA clasificados como críticos, y se cumple en los ejercicios de prueba?
- Q-RC-03: ¿Existe un proceso para identificar, revisar y, si procede, revocar las decisiones tomadas por el sistema de IA durante el período de compromiso?

4. Mapeo GQM → Indicadores IGM-FAICP

La siguiente tabla establece la trazabilidad completa desde los objetivos organizativos y preguntas GQM hasta los indicadores IGM-FAICP definidos en el informe principal:

Objetivo GQM	Pregunta GQM	Indicador IGM-FAICP	Función CSF 2.0	Peso en IGM
O-01	Q-GV-01	IGM-GV-01	GOBERNAR	$0.20 \times 1/6$
O-01	Q-GV-02	IGM-GV-02	GOBERNAR	$0.20 \times 1/6$
O-01	Q-GV-03	IGM-GV-03	GOBERNAR	$0.20 \times 1/6$
O-01	Q-GV-04	IGM-GV-04	GOBERNAR	$0.20 \times 1/6$
O-01	Q-GV-05	IGM-GV-05	GOBERNAR	$0.20 \times 1/6$
O-01	Q-GV-06	IGM-GV-06	GOBERNAR	$0.20 \times 1/6$
O-02	Q-ID-01	IGM-ID-01	IDENTIFICAR	$0.20 \times 1/5$
O-02	Q-ID-02	IGM-ID-02	IDENTIFICAR	$0.20 \times 1/5$
O-02	Q-ID-03	IGM-ID-03	IDENTIFICAR	$0.20 \times 1/5$
O-02	Q-ID-04	IGM-ID-04	IDENTIFICAR	$0.20 \times 1/5$
O-02	Q-ID-05	IGM-ID-05	IDENTIFICAR	$0.20 \times 1/5$
O-03	Q-PR-01	IGM-PR-01	PROTEGER	$0.25 \times 1/6$
O-03	Q-PR-02	IGM-PR-02	PROTEGER	$0.25 \times 1/6$
O-03	Q-PR-03	IGM-PR-03	PROTEGER	$0.25 \times 1/6$
O-03	Q-PR-04	IGM-PR-04	PROTEGER	$0.25 \times 1/6$
O-03	Q-PR-05	IGM-PR-05	PROTEGER	$0.25 \times 1/6$
O-03	Q-PR-06	IGM-PR-06	PROTEGER	$0.25 \times 1/6$
O-04	Q-DE-01	IGM-DE-01	DETECTAR	$0.15 \times 1/5$
O-04	Q-DE-02	IGM-DE-02	DETECTAR	$0.15 \times 1/5$
O-04	Q-DE-03	IGM-DE-03	DETECTAR	$0.15 \times 1/5$
O-04	Q-DE-04	IGM-DE-04	DETECTAR	$0.15 \times 1/5$
O-04	Q-DE-05	IGM-DE-05	DETECTAR	$0.15 \times 1/5$
O-05	Q-RS-01	IGM-RS-01	RESPONDER	$0.10 \times 1/4$
O-05	Q-RS-02	IGM-RS-02	RESPONDER	$0.10 \times 1/4$
O-05	Q-RS-03	IGM-RS-03	RESPONDER	$0.10 \times 1/4$
O-05	Q-RS-04	IGM-RS-04	RESPONDER	$0.10 \times 1/4$
O-06	Q-RC-01	IGM-RC-01	RECUPERAR	$0.10 \times 1/3$
O-06	Q-RC-02	IGM-RC-02	RECUPERAR	$0.10 \times 1/3$
O-06	Q-RC-03	IGM-RC-03	RECUPERAR	$0.10 \times 1/3$

5. Procedimiento de Aplicación del Marco

5.1. Ciclo de Medición Recomendado

T0 → Baseline: Primera aplicación completa (todos los indicadores)
T+6 → Revisión parcial: Indicadores Tier 1 y aquellos con puntuación < 2.5
T+12 → Revisión completa anual + actualización de pesos según cambio del contexto de amenazas
T+12 → Benchmarking externo: comparación con datos del Cisco CRI, ENISA ETL e INCIBE

5.2. Roles y Responsabilidades

Actividad	Responsable Principal	Validador
Definición de objetivos GQM nivel 1	AESIA / CCN	Dirección General
Definición de objetivos GQM nivel 2	CISO	Comité de Riesgos
Operacionalización de preguntas	Equipo de Seguridad IA	Arquitecto de Seguridad
Recogida de datos para métricas	Analistas de Seguridad	Auditor Interno
Cálculo del IGM-FAICP	Analista GRC	CISO
Revisión PRAGMATIC anual	Equipo de Mejora Continua	CISO + DPO
Reporte a AESIA / CCN	CISO + DPO	Dirección General

5.3. Herramientas de Soporte

- AI-BOM: SPDX 2.3+ (ISO/IEC 5962:2021) con campos extendidos para modelos de IA
- SIEM: Reglas de correlación específicas para las tácticas MITRE ATLAS (disponibles en ATLAScon)
- GRC: Integración con herramientas de GRC existentes (ServiceNow, Archer, OneTrust) mediante exportación JSON del IGM-FAICP
- Benchmarking: Cisco CRI Dashboard, ENISA NCSI, INCIBE datos abiertos
- Notificación regulatoria: Portal AESIA (sistemas EU AI Act) + plataforma ENISA (operadores NIS2)

6. Consideraciones de Validez y Limitaciones

6.1. Validez Interna

La validez interna del marco depende de la honestidad en la autoevaluación. El criterio **G (Genuino)** del PRAGMATIC es precisamente el más difícil de asegurar en entornos de autoevaluación. Para mitigarlo se recomienda:

- Triangulación con evidencias objetivas (logs, auditorías, pentest reports)
- Evaluaciones por terceros independientes al menos bienalmente
- Separación entre el equipo que implementa y el que evalúa los indicadores

6.2. Validez Externa y Comparabilidad

Para que los resultados sean comparables entre organizaciones y territorios, es imprescindible usar exactamente las mismas preguntas GQM y las mismas escalas de medición descritas en el Fichero (b) Matriz PRAGMATIC. Cualquier modificación local debe registrarse explícitamente para no contaminar los benchmarks agregados.

6.3. Evolución del Marco

El panorama de amenazas IA evoluciona a una velocidad que hace inadecuada la revisión anual como único ciclo. Se recomienda un mecanismo de **alerta temprana** que active revisiones extraordinarias de los indicadores ante:

- Publicación de nuevas versiones de MITRE ATLAS (v5.5 ya en marzo 2026)
- Actualización del OWASP LLM Top 10 (v2026 prevista)
- Nuevas guías de AESIA o CCN sobre sistemas específicos de IA
- Incidentes de IA de alta gravedad documentados por ENISA o INCIBE

*Documento generado como parte del Kit FAICP 2025-2026. Distribución libre con atribución.
Parte de una serie de 7 documentos: ver README.md para el índice completo.*